
MOHAN SINGH PARMAR

HAWKEYE LAB

Purple Team Report

Network Forensics & Incident Documentation

Project

HAWKEYE

Table of Contents

- [Purple Team Report](#)
 - [Cover Information](#)
 - [Table of Contents](#)
 - [Executive Summary](#)
 - [Purpose](#)
 - [Lab Overview](#)
 - [Red Team Summary](#)
 - [Blue Team Summary](#)
 - [Attack vs Defense Matrix](#)
 - [MITRE ATT&CK Mapping](#)
 - [Cyber Kill Chain Mapping](#)
 - [Security Controls](#)
 - [Preventive Controls](#)
 - [Detective Controls](#)
 - [Corrective Controls](#)
 - [Detection Improvements](#)
 - [Findings](#)
 - [Risk Prioritization](#)
 - [Recommendations](#)
 - [Lessons Learned](#)
 - [Final Handover Report](#)
 - [Conclusion](#)
 - [References](#)

Purple Team Report

Cover Information

Field	Detail
Project	HawkEye Lab Analysis
Author	Mohan Singh Parmar
Version	1.0
Date	2026-07-04
Classification	Internal / Portfolio Use
Source Evidence	<code>stealer.pcap</code> (4,003 packets, 2019-04-10 20:37:07 – 21:40:48 UTC)

Table of Contents

- 1. [Executive Summary](#)
- 2. [Purpose](#)
- 3. [Lab Overview](#)
- 4. [Red Team Summary](#)
- 5. [Blue Team Summary](#)
- 6. [Attack vs Defense Matrix](#)
- 7. [MITRE ATT&CK Mapping](#)
- 8. [Cyber Kill Chain Mapping](#)
- 9. [Security Controls](#)
- 10. [Detection Improvements](#)
- 11. [Findings](#)
- 12. [Risk Prioritization](#)
- 13. [Recommendations](#)

14. [Lessons Learned](#)
 15. [Final Handover Report](#)
 16. [Conclusion](#)
 17. [References](#)
-

Executive Summary

This Purple Team report brings together the offensive reconstruction (Red Team Report) and defensive analysis (Blue Team Report) produced from [stealer.pcap](#) into a single, correlated view. The exercise reconstructs an information-stealer infection against [Beijing-5cd1-PC](#) in the [pizzajukebox.com](#) domain: HTTP-based payload delivery, periodic environment fingerprinting via a third-party IP-check service, and recurring SMTP-based data exfiltration to an attacker-controlled mailbox. The purpose of this document is to map each attacker action to the corresponding detection and mitigation opportunity, prioritize remediation, and hand off a consolidated action plan to SOC, IT, and security engineering teams.

Purpose

Purple teaming exists to close the loop between offense and defense: every attacker technique identified by the Red Team should have a matching detection or preventive control validated by the Blue Team, and any gap should become a tracked remediation item. For HawkEye Lab, this means walking through the reconstructed attack chain phase by phase and asking, for each phase: *could we have detected this, and could we have prevented it?*

Lab Overview

HawkEye Lab is built around a single network capture of a real infostealer infection. Rather than running a live attacker/defender simulation, this exercise uses the pcap as ground truth for both teams: the Red Team report reconstructs “what happened,” and the Blue Team report reconstructs “how we would have known and responded.” This Purple Team report is the synthesis layer that ties the two together into actionable, prioritized guidance.

Red Team Summary

The reconstructed attacker path consisted of:

1. **Delivery** – A PE32 executable (`tkraw_Protected99.exe`, MD5 `71826ba081e303866ce2a2534491a2f7`) was downloaded over plain HTTP from `proforma-invoices.com` (`217.182.138.150`) using a spoofed, outdated **MSIE 7.0** user-agent string.
2. **Discovery** – The malware performed recurring **GET /** requests to `bot.whatismyipaddress.com` (`66.171.248.178`) approximately every 10 minutes to fingerprint the host's external IP.
3. **Exfiltration** – The malware established repeated SMTP sessions to `23.229.162.69:25`, authenticating as `sales.del@macwinlogistics.in` and sending mail to the same address – a “mail-to-self” exfiltration pattern typical of stealer/keylogger malware.
4. **No lateral movement or privilege escalation** was observed; all other traffic (Kerberos, SMB, LDAP) reflected normal domain-joined workstation behavior.

Full detail is available in `red-team-report.md`.

Blue Team Summary

From a defensive standpoint, the incident would ideally have generated alerts at multiple points:

- Proxy/URL-reputation alerting on the executable download from a low-reputation domain.
- Beacon-detection analytics on the fixed-interval `whatismyipaddress.com` requests.
- Egress-filtering alerts on direct SMTP traffic originating from a workstation rather than the approved mail relay.
- IOC/threat-intel matches on the identified IPs, domains, and file hashes once ingested into a TIP.

No confirmation is available in this capture that any of the above detections actually fired, which is itself the central finding of the Blue Team analysis: the necessary telemetry and controls were either absent or not yet tuned to catch this pattern. Full detail is available in `blue-team-report.md`.

Attack vs Defense Matrix

Attack Phase	Detection	Mitigation
Payload delivery over HTTP	Proxy log review for <code>.exe</code> downloads from uncategorized	

Attack Phase	Detection	Mitigation
	domains; user-agent anomaly detection	Web/email gateway sandboxing; block executable MIME types from uncategorized domains
Environment fingerprinting (IP-check beacon)	Beacon/regular-interval connection analytics in SIEM/NDR	Category-based web filtering blocking “IP lookup” utility sites from automated/background processes
SMTP-based exfiltration	Egress-filtering alert for TCP/25 from non-relay hosts; DLP content inspection at mail gateway	Firewall rule blocking direct outbound SMTP from all hosts except the approved mail relay
Sustained persistence (inferred)	Endpoint/EDR process and autoruns monitoring	Application allow-listing; EDR deployment fleet-wide
Domain/Kerberos activity	Baseline-normal; monitor for anomalous logon types as a general control	Standard AD hardening (tiered administration, Kerberos hardening) — not specific to this incident

MITRE ATT&CK Mapping

Tactic	Technique	Attacker Action	Detection Control	Preventive Control
Initial Access	T1566 – Phishing (inferred)	Lure-themed executable delivered via link/attachment	Email gateway attachment/link scanning	Sandboxing, attachment stripping
Execution	T1204.002 – User Execution	User/script executes downloaded file	Sysmon Event ID 1 process creation monitoring	Application allow-listing
Discovery	T1016 – System Network Configuration Discovery	Repeated external IP-check requests	Beacon-interval detection	Category-based web filtering
Command and Control	T1071.001 – Web Protocols	HTTP used for check-in traffic	Proxy/NDR anomaly detection	

Tactic	Technique	Attacker Action	Detection Control	Preventive Control
				TLS interception + domain reputation filtering
Exfiltration	T1048.003 – Exfiltration Over Alternative Protocol (SMTP)	Automated SMTP sessions to attacker mailbox	Egress SMTP monitoring/DLP	Firewall-enforced mail relay restriction

Cyber Kill Chain Mapping

Kill Chain Phase	Observed Activity
Reconnaissance	Not observable in this capture (pre-delivery activity, e.g. target selection/lure crafting, occurred outside the capture window)
Weaponization	Not observable directly; the delivered file is the weaponized payload
Delivery	HTTP download of <code>tkraw_Protected99.exe</code> from <code>proforma-invoices.com</code>
Exploitation	User/script-driven execution of the downloaded binary (inferred from subsequent network behavior)
Installation	Not directly observable; sustained beacon/exfil activity across the capture window implies the malware remained resident and running
Command and Control	Periodic HTTP beacon to <code>bot.whatismyipaddress.com</code>
Actions on Objectives	Recurring SMTP exfiltration to <code>sales.del@macwinlogistics.in</code> via <code>23.229.162.69</code>

Security Controls

Preventive Controls

- Application allow-listing on endpoints to block unapproved executable execution.
- Firewall rules restricting outbound SMTP (TCP/25) to only the approved internal mail relay.
- Web/email gateway sandboxing of downloaded attachments and links before user delivery.
- DNS filtering/RPZ blocking known-bad and newly-registered domains.

Detective Controls

- SIEM correlation rules for fixed-interval outbound beaconing.
- Proxy/IDS signatures for executable downloads with anomalous user-agent strings.
- Egress DLP inspection on outbound SMTP traffic.
- Threat-intelligence-fed IOC matching (IPs, domains, hashes from this incident).

Corrective Controls

- Endpoint isolation/quarantine automation triggered by beacon or exfiltration detections.
 - Automated credential-rotation workflow following confirmed stealer-malware detonation.
 - Incident response playbook specific to information-stealer / BEC-adjacent incidents.
-

Detection Improvements

- **SIEM Rules:** Add a correlation rule flagging any single internal host generating outbound HTTP requests to the same external host at a near-constant interval (e.g., ± 30 seconds) more than 3 times within an hour.
 - **IDS Rules:** Add signatures for SMTP **AUTH LOGIN** sessions originating from IP ranges assigned to end-user workstation subnets rather than server/relay subnets.
 - **EDR Improvements:** Ensure process-to-network correlation (e.g., Sysmon Event ID 3) is enabled fleet-wide so that any future beacon/exfil traffic can be immediately tied to a responsible process and binary.
 - **Threat Hunting:** Proactively hunt for any other internal hosts contacting **217.182.138.150**, **66.171.248.178**, **23.229.162.69**, **proforma-invoices.com**, or **macwinlogistics.in** historically in DNS/firewall logs, in case of a broader campaign.
 - **Log Correlation:** Correlate proxy logs (executable download), firewall logs (SMTP egress), and DNS logs (lookup for exfiltration domain) into a single incident timeline/case file for faster future triage.
-

Findings

Critical

- Sustained, unimpeded SMTP-based data exfiltration to an external, attacker-controlled mailbox over more than an hour of observed traffic, with no evidence of the exfiltration having been blocked or alerted upon.

High

- Malicious executable delivered and (inferred) executed with no evidence of application allow-listing or sandboxing having intervened.

Medium

- Regular-interval beaconing to a third-party IP-check service went unblocked, indicating a gap in web-filtering/behavioral-detection coverage.

Low

- Use of an outdated/spoofed user-agent string in the malicious HTTP request — a low-cost, high-value detection signature that appears to have gone unused.
-

Risk Prioritization

Priority	Item	Rationale
1	Restrict SMTP egress to approved mail relay only	Directly stops the confirmed, ongoing exfiltration vector
2	Deploy/verify application allow-listing and endpoint sandboxing	Prevents the initial execution step of this and similar malware
3	Implement beacon-interval detection analytics	Closes the detection gap that allowed the beacon and exfil activity to continue undetected for over an hour
4	Ingest IOCs into threat-intelligence platform and block at DNS/firewall layer	Prevents recurrence from the same known infrastructure
5	Expand phishing-lure security awareness training	

Priority	Item	Rationale
		Addresses the most likely (though not directly confirmed) initial-access vector

Recommendations

1. **Immediate (0–7 days):** Block all identified IOCs at firewall/DNS; isolate and reimage the affected host; rotate potentially exposed credentials.
 2. **Short-term (7–30 days):** Implement SMTP egress restriction fleet-wide; deploy or tune beacon-detection analytics in the SIEM/NDR platform.
 3. **Medium-term (30–90 days):** Roll out application allow-listing and email/web gateway sandboxing where not already in place; onboard the confirmed IOCs into the organization’s threat-intelligence platform.
 4. **Long-term (90+ days):** Establish a recurring purple-team exercise cadence using real-world pcap samples (such as this one) to continuously validate detection coverage against evolving commodity malware techniques.
-

Lessons Learned

- This engagement demonstrates that a single, well-analyzed packet capture can drive a complete purple-team exercise — mapping attacker technique to detection gap to concrete control — without requiring a live-fire range.
 - The most impactful single control identified was SMTP egress restriction: a simple firewall policy change would have prevented the confirmed data-loss impact of this entire incident, regardless of whether the initial infection was prevented.
 - Behavioral/interval-based detection (beaconing) proved more valuable in this case than signature-based detection, since the payload delivery itself used no unusual protocol — only well-known evasion patterns (spoofed user-agent, uncategorized domain).
-

Final Handover Report

Attack Summary

An end-user workstation was infected via a downloaded executable disguised as an invoice-related file. The malware fingerprinted the host's external IP on a fixed schedule and exfiltrated data via automated SMTP sessions to an external mailbox, repeating this cycle roughly every ten minutes for the duration of the observed capture.

Defensive Summary

No confirmed evidence exists in the available data that any preventive or detective control intervened at any stage of this attack chain. The incident was reconstructed entirely from network capture rather than from SOC alert history, indicating a coverage gap in monitoring for this attack pattern at the time of capture.

Remaining Risks

- Scope of data already exfiltrated prior to detection is unknown without endpoint/mailbox-side forensics.
- Other hosts on the network may have been exposed to the same delivery infrastructure; this has not been ruled out.
- The initial delivery vector (phishing email, drive-by, or otherwise) remains unconfirmed pending mail-gateway log review.

Business Impact

Potential compromise of user credentials, keystrokes, or screen captures represents a significant confidentiality risk, with possible downstream impact including account takeover, financial fraud (particularly given the invoice-themed lure, suggestive of Business Email Compromise targeting), and reputational harm if customer or partner data was captured.

Future Improvements

Adopt the phased recommendations above, with SMTP egress restriction and beacon-detection analytics prioritized as the highest-value, lowest-effort improvements.

SOC Recommendations

Build and deploy the SIEM/IDS detection rules outlined in this report; integrate the confirmed IOCs into active blocklists and threat-intelligence feeds without delay.

Red Team Recommendations

Use this pcap and its reconstructed attack chain as a template for future purple-team exercises simulating similar delivery-beacon-exfiltration patterns, to continuously validate whether the recommended controls remain effective as the environment changes.

Blue Team Recommendations

Prioritize closing the SMTP-egress and beacon-detection gaps identified in this report, and validate closure through a follow-up purple-team replay of this same traffic pattern against the improved control set.

Conclusion

This Purple Team exercise successfully correlated a reconstructed attacker kill chain with the corresponding defensive detection and prevention opportunities, using a single network capture as the sole source of ground truth. The exercise highlights that the most damaging phase of this attack — sustained SMTP-based data exfiltration — was also the most straightforward to prevent through basic network egress control, underscoring the value of foundational security hygiene alongside more advanced detection engineering.

References

- MITRE ATT&CK Framework: <https://attack.mitre.org/>
- Lockheed Martin Cyber Kill Chain: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- [red-team-report.md](#) and [blue-team-report.md](#) (companion documents, this repository)
- Replace this section with any additional internal purple-team methodology documentation used for HawkEye Lab.